

Slider Revolution Plugin Critical Vulnerability Being Exploited

Slider Revolution Plugin Critical Vulnerability Being Exploited - @sucurisecurity, Sucuri Blog.

- Published: 2014-09-03
- Original: <<https://web.archive.org/web/20160403035045/http://blog.sucuri.net/2014/09/slider-revolution-plugin-critical-vulnerability-being-exploited.html>>
- Current location:
<<https://web.archive.org/web/20160404231346/https://blog.sucuri.net/2014/09/slider-revolution-plugin-critical-vulnerability-being-exploited.html>>
- Preserved from:
<https://web.archive.org/web/20160404231346/https://blog.sucuri.net/2014/09/slider-revolution-plugin-critical-vulnerability-being-exploited.html> (live) on 2026-08-09
- Capture timestamp: 20160403035045
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source from the Web Hacking Techniques Index collections, kept so the page going offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

***12.17.2014:** See more information on the SoakSoak massive malware outbreak resulting from this vulnerability: [RevSlider Vulnerability Leads To Massive WordPress SoakSoak Compromise](#) by Daniel Cid

[Mika Epstein, Ipstenu, of Dreamhost](#), notified us today of a serious vulnerability in the WordPress Slider Revolution Premium plugin which was patched silently.

It turns out that the vulnerability was disclosed via some underground forums. ThemePunch confirms that their plugin was patched in version 4.2 for those that purchase the plugin directly from them, and they include an auto-updater which would address the problem. The real issue lies in the way the plugin is wrapped into theme packages. ThemePunch's approach to disclosing the issue was based on guidance they received.

This a very popular plugin, and appears to be one of the most downloaded slider plugins from [Envato's Marketplace – Code Canyon](#). It also appears to be bundled in theme packages so be sure to check your theme / plugins.

This is an example of where things go terribly wrong.

In this situation, a very popular plugin developer decided it was best not to disclose to anyone, in return patching silently. Mind you, this vulnerability was already disclosed as a Zero Day via underground forums, which you would have thought would incentivize a developer to work quickly and disclose even faster. No, instead a different course of action was taken.

Now, the vulnerability is being actively exploited in the wild. Yes, the vulnerability is severe enough that the attackers are able to compromise websites through it.

WordPress Slider Revolution Vulnerability

About 2 months ago someone publicly disclosed a serious vulnerability in the Slider Revolution Premium WordPress Plugin that allows a remote attacker to download any file from the server.

The proof of concept shared via underground sites shows how someone can easily download the **wp-config.php**:

```
http://victim.com/wp-admin/admin-ajax.php?action=revslider_show_image&img=../wp-config.php
```

This is used to steal the database credentials, which then allows you to compromise the website via the database.

This type of vulnerability is known as a Local File Inclusion (LFI) attack. The attacker is able to access, review, download a local file on the server. This, in case you're wondering is a very serious vulnerability that should have been addressed immediately.

Local File Inclusion (also known as LFI) is the process of including files on a server through the web browser.

UPDATE IMMEDIATELY!!!

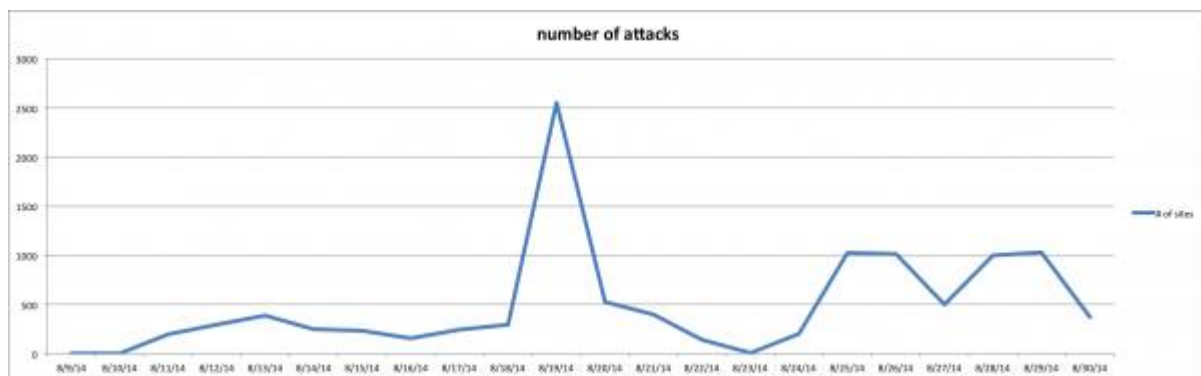
Attacks In The Wild

We thought it'd be in our interest to see how active attacks against this vulnerability were. We turned to our [WAF](#) logs and found that this vulnerability is being actively attacked in the wild. Today alone, there were 64 different IP addresses trying to trigger this vulnerability on more than 1,000 different websites within our environment.

Here is a snippet of what to look for in your access logs:

194.29.185.106 - - [02/Sep/2014...] "GET /wp-admin/admin-ajax.php?action=revslider_show_image&img=../wp-config.php
 85.103.12.6 - - [02/Sep/2014...] "GET /wp-admin/admin-ajax.php?action=revslider_show_image&img=../wp-config.php
 91.229.229.201 - - [02/Sep/2014...] "GET /wp-admin/admin-ajax.php?action=revslider_show_image&img=../wp-config.php
 85.103.12.6 - - [02/Sep/2014...] "GET /wp-admin/admin-ajax.php?action=revslider_show_image&img=../wp-config.php
 85.103.12.6 - - [02/Sep/2014...] "GET /wp-admin/admin-ajax.php?action=revslider_show_image&img=../wp-config.php
 94.242.246.23 - - [02/Sep/2014...] "GET /wp-admin/admin-ajax.php?action=revslider_show_image&img=../wp-config.php
 74.120.13.132 - - [02/Sep/2014...] "GET /wp-admin/admin-ajax.php?action=revslider_show_image&img=../wp-config.php
 77.247.181.165 - - [02/Sep/2014...] "GET /wp-admin/admin-ajax.php?action=revslider_show_image&img=../wp-config.php
 37.148.163.38 - - [02/Sep/2014...] "GET /wp-admin/admin-ajax.php?action=revslider_show_image&img=../wp-config.php
 37.130.227.133 - - [02/Sep/2014...] "GET /wp-admin/admin-ajax.php?action=revslider_show_image&img=../wp-config.php

It appears that via our environment, the attack appears to begin on August 09th, growing significantly on Aug 19:



Yes, if you are a client of our Website Firewall you are already being protected via our virtual hardening and patching mechanisms. No, if you leverage the latest WordPress Security utility plugin you are likely not being protected.

Update Now!

If you use the WordPress Slider Revolution Premium plugin, you have to update it immediately! We also wish the developers were more open and had publicized the issue and alerted their customers of the problem beforehand. This type of action is an example of what not to do, especially if you find out about the issue via a Zero Day disclosure.

Update - 20140903 - Which Versions Affected*

This is a Premium plugin, this means we don't have insights into the way they structure or release their plugins. We are however reaching out to the development team to confirm the exact date of the patch. There is mention of a patch in February, but because we have no insights into the older version of the plugin it is hard to confirm if it's related to this or something else.

To illustrate the problem, here is a comment from one of the users of the plugin:

I have this plugin installed on a number of sites but none of the plugins are prompting me to update. In fact they're all showing different version numbers: 2.03, 2.1.7, 2.3.91, 3.0.5, and 4.1.4

while the latest version on CodeCanyon is 4.5. Any idea why there is no option to update from within the WordPress dashboard? Thanks for bringing this to our attention!

If we hear back from the developers we will update accordingly.

The biggest challenge with this vulnerability is that it appears to be bundled in many theme packages. This means theme shops have paid for a developer license and are releasing the plugin with or making it optional to users. Users may or may not know they have the plugin installed because of this. We are also noticing that while most theme packages have updaters, they don't update the plugins, only the themes which causes more confusion to the process.

Update - 20140903 - Affected Themes*

A more comprehensive list of themes packages **possibly** affected include:

```
# WordPress IncredibleWP Theme Arbitrary File Download
# Vendor Homepage: http://freelancewp.com/wordpress-theme/incredible-wp/
# Google Dork: "Index of" +/wp-content/themes/IncredibleWP/

# WordPress Ultimatum Theme Arbitrary File Download
# Vendor Homepage: http://ultimatumtheme.com/ultimatum-themes/s
# Google Dork: "Index of" +/wp-content/themes/ultimatum

# WordPress Medicate Theme Arbitrary File Download
# Vendor Homepage: http://themeforest.net/item/medicate-responsive-medical-and-health-theme/3707916
# Google Dork: "Index of" +/wp-content/themes/medicate/

# WordPress Centum Theme Arbitrary File Download
# Vendor Homepage: http://themeforest.net/item/centum-responsive-wordpress-theme/3216603
# Google Dork: "Index of" +/wp-content/themes/Centum/

# WordPress Avada Theme Arbitrary File Download
# Vendor Homepage: http://themeforest.net/item/avada-responsive-multipurpose-theme/2833226
# Google Dork: "Index of" +/wp-content/themes/Avada/

# WordPress Striking Theme & E-Commerce Arbitrary File Download
# Vendor Homepage: http://themeforest.net/item/striking-multiflex-ecommerce-responsive-wp-theme/128763
# Google Dork: "Index of" +/wp-content/themes/striking_r/

# WordPress Beach Apollo Arbitrary File Download
# Vendor Homepage: https://www.authenticthemes.com/theme/apollo/
# Google Dork: "Index of" +/wp-content/themes/beach_apollo/
```

Released on [Exploit-DB September 1st, 2014](#). The emphasis on **possibly** is because if you are running the latest version of the theme, you might be ok, you might also not be ok.

It all depends on how the theme packager bundles the plugins and handles the upgrades. That, we can't and won't speak to.

If you know of more theme package feel free to let us know and we'll be happy to update the list to ensure everyone is made aware equally and without prejudice. The emphasis here is to update your plugin, we do not intend to focus on any theme shops, their practice for handling dev licenses or any variation of that.

Update - 20140903 - ThemePunch Response*

Here is the response from the developers of the plugin, found in the comment thread below:

Hi,

The problem was fixed 29 updates back in 4.2 in February. We were told not to make the exploit public by several security companies so that the instructions of how to hack the slider will not appear on the web.

You should always keep the slider up to date like any other WordPress component but urgently need to do this when using Version 4.1.4 or below in order to fix the security issue. Please use the included autoupdate feature (we solve issues within hours and update nearly every two weeks if nothing special needs a faster frequency).

We are sorry for you guys out there whose slider came bundled with a theme and the theme author did not update the slider. Since you cannot use the included autoupdate function please contact your theme author and inform him about his failure!

Best regards, ThemePunch

Here is the change log from February:

Version 4.2 SkyWood (25th February 2014) including Security Fix

NEW FEATURES

- New Activation process added
- New Automatic Updates process added
- Added Char, Word and Line Based Text animation to improve the Visual Experience on the Layer Animations
- Added 5 Different Loader Spinner with Live Preview Selector
- Added a new Shortcode type. Now [rev_slider slider_alias] and also [rev_slider alias="slider_alias"] works.
- Added polish language thanks to Dawid Dudek (www.supportitc.pl)
- Meta Box for RevSlider now available in all Custom Post Types
- Added remove Thumbnail in Slide Editor
- Added white-space, maxwidth and maxheight options

CHANGES

- Improved Loading Speed. Slider loads over 1-2 sec quicker than before.
- Improved Lazy Loading, to load Images and Layer images on demand. Intelligent Preloading of next slide Elements.
- Removed function mysql_insert_id() that will be deprecated in php version 5.5.x
- Auto Thumbnail Function, small copy of Slider Image, or Colorer BG used as Default.

BUGFIXES

- **Fixed Security Issue**
- Fixed YouTube Api
- CSS editor bugfix where custom styles were set into other choosen layers
- Added missing argument for WPML, this enables WPML functionality in using the specific post feature
- Small adjustment for css editor that caused problems on some installations
- Check if ssl on external jquery library & css include
- Fixed Overlapping layers if Mixed Align Mode used in Slide
- Fixed Pause/Resume function if Navigation elements has been hovered.
- MultiSite Style Settings – Minor Workaround added till next Major Release

Slider Revolution Changelog

The real issue here appears to be with how theme packages incorporate and subsequently update plugins their themes depend on.

Update - 20140904 - More themes that might be affected*

These themes include the plugin and might be affected as well:

X Theme (2nd highest selling theme) – <http://themeforest.net/item/x-the-theme/5871901>

Bridge Theme – <http://themeforest.net/item/brooklyn-creative-one-page-multipurpose-theme/6221179>

The7 – <http://themeforest.net/item/the7-responsive-multipurpose-wordpress-theme/5556590>

Total – <http://themeforest.net/item/total-responsive-multipurpose-wordpress-theme/6339019>

BeTheme – <http://themeforest.net/item/betheme-responsive-multipurpose-wordpress-theme/7758048>

Inovado – <http://themeforest.net/item/inovado-retina-responsive-multipurpose-theme/3810895>

Porto – <http://themeforest.net/item/metronic-responsive-admin-dashboard-template/4021469>

Metronix – <http://themeforest.net/item/metronic-responsive-admin-dashboard-template/4021469>

Jupiter – <http://themeforest.net/item/jupiter-multipurpose-responsive-theme/5177775>

Newspaper – <http://themeforest.net/item/newspaper/5489609>

uDesign – <http://themeforest.net/item/udesign-responsive-wordpress-theme/253220>

Update – 20140905 – Envato Release *

Envato has releases the [comprehensive list of the themes affected by this vulnerability](#).

Archived from <https://web.archive.org/web/20160403035045/http://blog.sucuri.net/2014/09/slider-revolution-plugin-critical-vulnerability-being-exploited.html>. Rendered offline from the local Markdown copy.